

Plantilla de Excel para cálculo de Índice Global de Madurez (IGM) y ROI de Seguridad

Este documento describe cómo estructurar una hoja de cálculo (Excel u otra) para calcular:

- Un Índice Global de Madurez (IGM) del sistema de indicadores ISO 27001.
- Indicadores económicos básicos, incluyendo un ROI de seguridad, a partir de las respuestas de la encuesta y de datos económicos internos. [web:4][web:13]

1. Estructura general del libro

Se recomienda un libro con las siguientes hojas:

1. RESPUESTAS_ENCUESTA – captura codificada de respuestas.
2. PONDERACIONES – pesos asignados a bloques y preguntas.
3. CALCULO_IGM – cálculo del índice de madurez y subíndices.
4. DATOS_ECONOMICOS – costes, pérdidas evitadas, etc.
5. CALCULO_ROI – métricas económicas consolidadas.
6. CUADRO_MANDO – resumen visual para reporte ejecutivo.

2. Hoja RESPUESTAS_ENCUESTA

- Una fila por organización.
- Una columna por pregunta codificada (por ejemplo, P2_1, P2_2, etc.).
- Codificación numérica de las respuestas cerradas.

Ejemplos de codificación:

- Preguntas tipo escala (por ejemplo, grado de cobertura): 1–5.
- Preguntas sí/no: 1 = sí, 0 = no.
- Niveles de madurez (1–5) ya vienen en formato numérico.

Se pueden incluir columnas adicionales con metadatos (sector, tamaño, etc.) para análisis posteriores.

3. Hoja PONDERACIONES

Definir:

- Peso por bloque de la encuesta (por ejemplo, B2_GOBERNANZA, B3_METODOLOGIA, etc.).
- Peso por pregunta dentro de cada bloque, si se desea un nivel de granularidad mayor.

Ejemplo:

Bloque	Peso bloque	Pregunta	Peso pregunta
Gobernanza (B2)	0,15	P2_1	0,3
		P2_2	0,25
		P2_3	0,25
		P2_4	0,2
Metodología (B3)	0,10	...	...
Riesgos (B5)	0,15	...	...
Técnicos (B6)	0,15	...	...
Incidentes (B7)	0,15	...	...
Concienciación (B8)	0,10	...	...
Resiliencia (B9)	0,10	...	...
Regulación (B11)	0,10	...	...

Los pesos pueden ajustarse según el foco del estudio (por ejemplo, mayor peso a resiliencia en sectores críticos).

4. Hoja CALCULO_IGM

4.1 Subíndices por bloque

Para cada organización (fila), calcular un subíndice por bloque:

- Ejemplo (en pseudo-fórmula Excel):

$$\text{SUBINDICE_B2} = \text{SUMA}(\text{P2_1_normalizada} * \text{peso_P2_1} + \dots)$$

Las respuestas numéricas se normalizan a un rango 0–1, si es necesario:

- $\text{valor_normalizado} = (\text{valor} - \text{mínimo}) / (\text{máximo} - \text{mínimo})$

4.2 Índice Global de Madurez (IGM)

Calcular el IGM ponderando los subíndices:

- $$\text{IGM} = \text{SUMA}(\text{SUBINDICE_B2} * \text{peso_B2} + \text{SUBINDICE_B3} * \text{peso_B3} + \dots)$$

El resultado se deja en escala 0–1, o se multiplica por 100 para expresarlo como porcentaje.

Puede añadirse una categorización automática:

- 0,00–0,19 → Nivel 1 – Reactivo
- 0,20–0,39 → Nivel 2 – Básico
- 0,40–0,59 → Nivel 3 – Definido
- 0,60–0,79 → Nivel 4 – Gestionado
- 0,80–1,00 → Nivel 5 – Optimizado

4.3 Subíndices temáticos

Opcionalmente, definir subíndices por tema:

- IGM_RIESGOS – basado en preguntas de gestión de riesgos.
- IGM_TECNICO – basado en vulnerabilidades, SOC, etc.
- IGM_CULTURA – basado en concienciación y comportamiento.
- IGM_RESILIENCIA – basado en continuidad, incidentes, etc.

Esto permite identificar fortalezas y debilidades específicas.

5. Hoja DATOS_ECONOMICOS

Recoger para cada organización:

- Costes de seguridad anuales (CAPEX, OPEX).
- Costes asociados a incidentes en un periodo de referencia (pérdidas directas, tiempo de inactividad, sanciones, etc.).
- Estimaciones de pérdidas evitadas (por ejemplo, reducción de incidentes, menor tiempo de parada, etc.).

Estructura sugerida:

Org_ID	Año	Coste_Seguridad	Pérdidas_Incidentes	Pérdidas_Evitadas_Estimadas	Comentarios

Las estimaciones pueden apoyarse en datos históricos o benchmarks sectoriales.

6. Hoja CALCULO_ROI

Definir un indicador sencillo de ROI de seguridad:

- Fórmula orientativa:

$$\text{ROI_seguridad} = (\text{Pérdidas_Evitadas_Estimadas} - \text{Coste_Seguridad}) / \text{Coste_Seguridad}$$

Expresado en porcentaje:

- $\text{ROI_}\% = \text{ROI_seguridad} * 100$

Se pueden incorporar matices:

- Separar efectos de iniciativas concretas (proyectos) frente a la operación recurrente.
- Añadir indicadores de eficiencia (por ejemplo, coste por incidente evitado, coste por punto de IGM, etc.).

Ejemplos de campos calculados:

- $\text{Coste_por_punto_IGM} = \text{Coste_Seguridad} / (\text{IGM} * 100)$
- $\text{Coste_por_incidente_gestionado} = \text{Coste_Seguridad} / \text{N}^{\circ}_\text{incidentes_gestionados}$

7. Hoja CUADRO_MANDO

Esta hoja resume los resultados en gráficos y tablas:

- Distribución de IGM por sector, tamaño, tipo de organización.
- Relación entre IGM y ROI (diagrama de dispersión).
- Mapas de calor de subíndices por bloque/tema.
- Indicadores clave para reporte ejecutivo (p. ej., % de organizaciones con $\text{IGM} \geq 0,6$).

Para facilitar la vida al CISO, se recomienda incluir:

- Semáforos (verde/ámbar/rojo) por bloque.
- Comentarios automáticos (“La organización presenta un nivel de madurez X con áreas de mejora en Y y Z”).

8. Notas metodológicas

- El cálculo de IGM y ROI es orientativo y debe adaptarse al contexto de cada proyecto.
- Se recomienda documentar los supuestos de estimación de pérdidas evitadas y revisar anualmente los parámetros. [web:4][web:13]
- El objetivo no es lograr la precisión de un acelerador de partículas, sino un nivel de aproximación útil para priorizar decisiones y justificar inversiones.